

Vulnerability Assessment with OWASP ZAP

Overview



OWASP Zed Attack Proxy (ZAP) is the world's most widely used web application security testing tool which is free and open source. IS students should be familiar with this tool, but for the benefit of SE students, this lab will introduce how to use OWASP ZAP for performing vulnerability assessment (VA) of a web application during Secure Software Verification phase.

Outcomes

Upon completion of this lab, you should be able to:

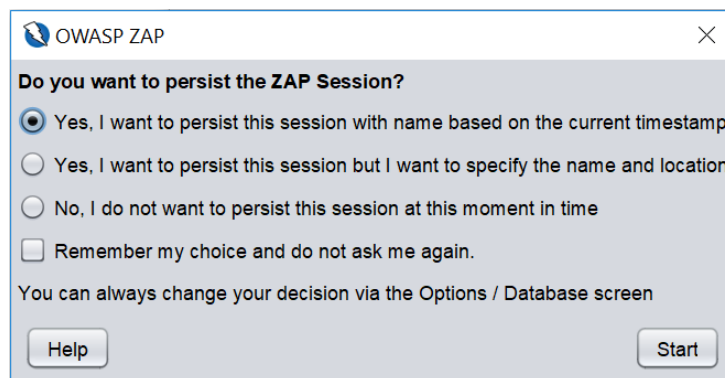
- Practice vulnerability assessment on an intentionally vulnerable web application using OWASP ZAP
- Use OWASP ZAP to perform vulnerability assessment for your team project

1: Pre-requisite

OWASP ZAP

Download and install OWASP ZAP from <https://www.zaproxy.org/> .

When you first run ZAP, you will be asked if you want to persist the ZAP session. By default, ZAP sessions are always recorded to disk with a default name and location. If you do not persist the session, those files are deleted when you exit ZAP..



Damn Vulnerable Web Application (DVWA)

Install DVWA following the instructions in:

<https://github.com/FarizDeveloper/DVWA>

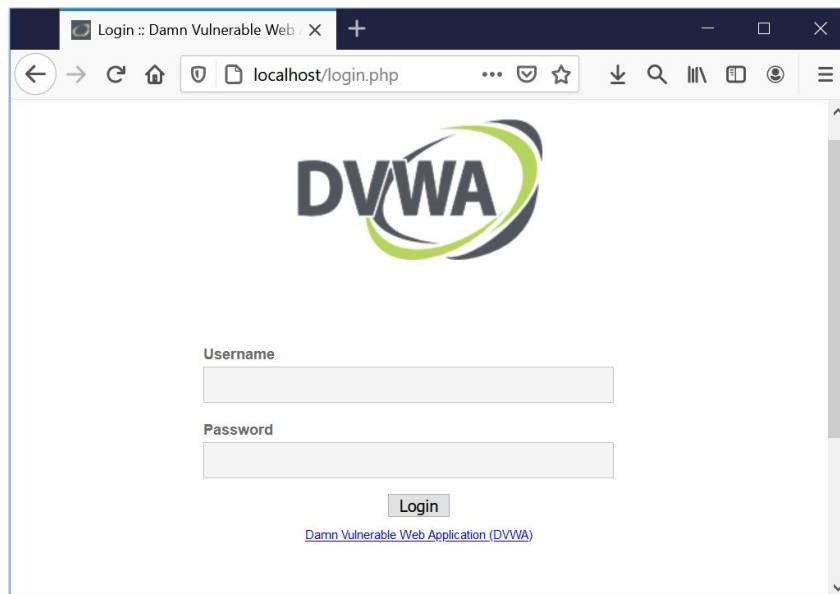
While there are various versions of DVWA around, the only supported version is the latest source from the official GitHub repository. You can either clone it from the repo:

```
git clone https://github.com/digininja/DVWA.git
```

Or download a ZIP of the files at:

<https://github.com/digininja/DVWA/archive/master.zip>

The simplest way to run DVWA is to host it locally using XAMPP that you have learned in ICT1004. Unzip DVWA and move it to the web root of XAMPP. Next, start a browser to visit your locally hosted DVWA and follow the instructions to initialise it. When done, you should be able to see the DVWA login page as shown:

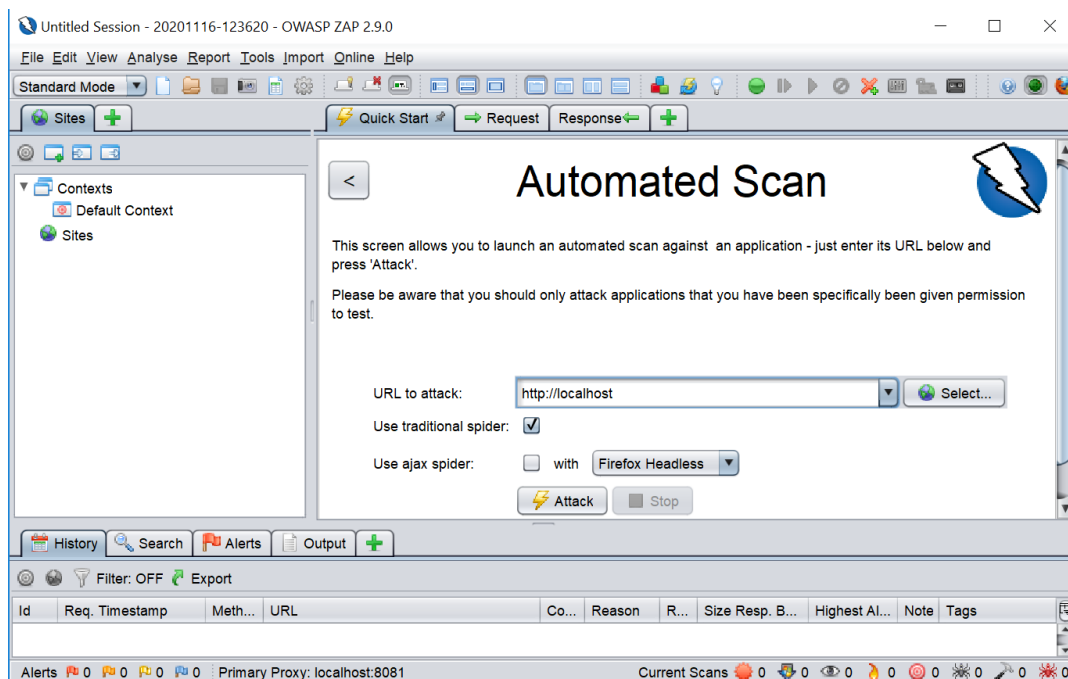


2: Performing Vulnerability Assessment (VA) on Web Application

Performing Vulnerability Assessment

The simplest way to start using OWASP ZAP is to click the 'Automated Scan' button on the ZAP workspace window and then enter the URL to attack, an example as shown:

(Important: It's a criminal offence to scan a web site without authorised permission!)

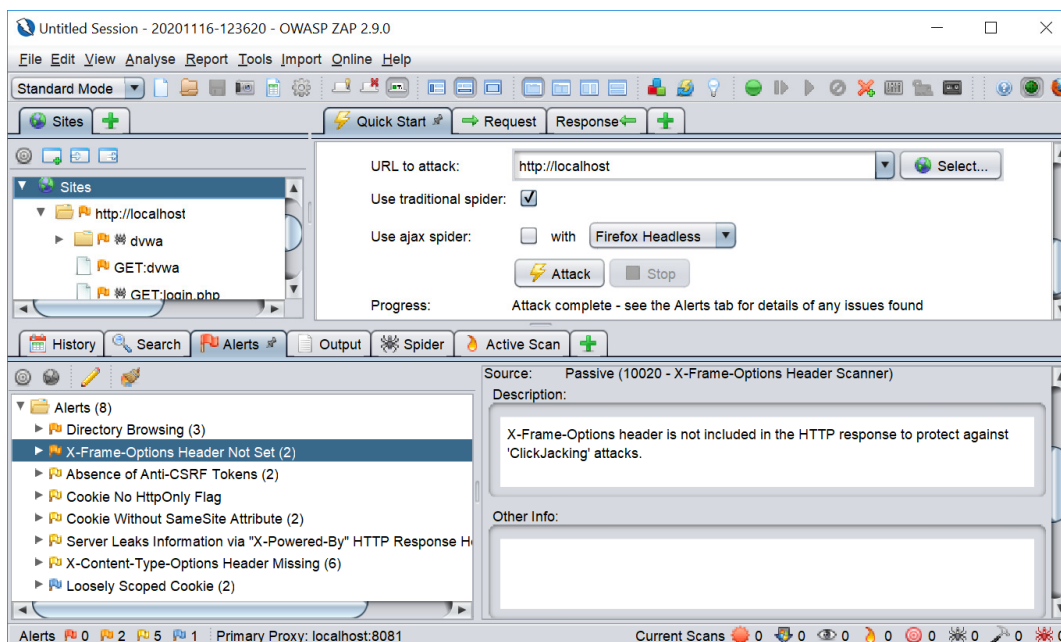


ZAP implements two different spiders to crawl the web application under attack. The traditional spider discovers links by examining the HTML in responses from the web application. This spider is fast, but it is not always effective when exploring an AJAX web application that generates links using JavaScript.

For AJAX applications, ajax spider is likely to be more effective. This spider explores the web application by invoking browsers which then follow the links that have been generated. However, it is slower than the traditional spider and requires additional configuration for use in a "headless" environment.

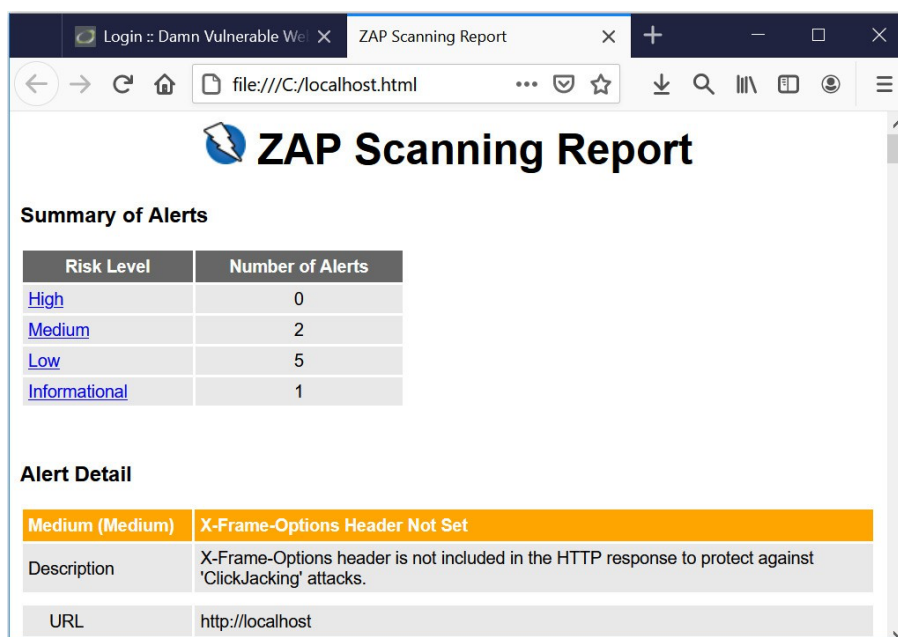
When ready, click the 'Attack' button which will activate ZAP to crawl the web application with its spider and passively scan each page it finds. Then it will use the active scanner to attack all of the discovered pages, functionality, and parameters. Give some time for it to run.

When done, go to the 'Alerts' tab where you will find the discovered vulnerabilities, an example as shown:



Generating Report

OWASP ZAP has a nice feature to generate reports of the discovered vulnerabilities. Just go to the top menu bar, select 'Report' where a drop-down menu will allow you to choose the different report formats that you prefer. An example of .html report is shown:



To learn more features of OWASP ZAP, do read the documentation, and enjoy performing vulnerability assessment in your team project!

3: References

OWASP ZAP Documentation <https://www.zaproxy.org/docs/>

END OF DOCUMENT